

HEAD MARE PHANTOMGRAPH SERVICE PERSISTENCE

Campaign hunt for Windows service installation that launches a temporary command batch through cmd.exe.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

SecurityEvent · 4697

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

13 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Sentinel · SecurityEvent
· 4697

ATT&CK

T1543.003

Evidence-led dossier. Query status remains an untested implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Detect the source-observed service registration pattern.

Kaspersky observed Head Mare installing the PhantomGraph modules as Windows services named SysExcSvc and SysReadSvc. The registered service command invokes %TEMP%\cmd_cmd_*.bat through cmd /c. Windows Security Event 4697 directly records the service name and service file command.

OPERATIONAL VALUE

Direct persistence metadata with strong campaign context.

Event 4697 captures the configuration at installation time, before later execution may be obscured. The exact service names and temporary batch pattern sharply constrain benign overlap, while the hunting classification acknowledges that these artifacts are mutable and not yet tested in the target workspace.

9.0

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- The July 2026 campaign compromised vulnerable TrueConf servers.
- PhantomGraph installs SysExcSvc and SysReadSvc as Windows services.
- The source documents cmd /c and a %TEMP%\cmd_cmd_*.bat service command pattern.

ANALYTICAL ASSESSMENT

What the evidence supports

- Event 4697 is the most direct supported record of service installation metadata.
- Requiring service name, cmd /c and the Temp batch pattern is stronger than any artifact alone.
- A match is a campaign lead, not proof of TrueConf exploitation or Head Mare attribution.

DETECTION ASSUMPTIONS

What must be validated

- Audit Security System Extension is enabled and Event 4697 reaches Sentinel.
- SecurityEvent populates ServiceName and ServiceFileName for the event.
- Legitimate software does not reproduce the complete combination.

Confidence boundary

The query does not prove that the service started, the batch executed, PhantomGraph loaded, OneDrive was used for C2, LSASS was dumped, or TrueConf was the initial vector. Service names and filenames can change.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Exploit server

Head Mare chains two TrueConf flaws to reach SYSTEM.

02

Deploy web shell

The actor replaces publicjs\locale.php for remote control.

03

Stage modules

SysExcSvc.dll and SysReadSvc.dll are placed under inetsrv.

04

Register services

PowerShell creates SysExcSvc and SysReadSvc through a Temp batch command.

05

Operate backdoor

The modules exchange commands and results; OneDrive supports C2.

Observable core

One Windows Security Event 4697 containing a source-observed service name and the cmd /c to Temp cmd_cmd_*.bat command pattern.

Non-observable boundary

Exploit success, web-shell content, batch execution result, DLL loading, OneDrive communications, credential access and actor attribution.

DETECTION HYPOTHESIS

The PhantomGraph persistence handoff should be retained in service-installation telemetry.

If an attacker repeats the documented PhantomGraph installation, SecurityEvent should record Event ID 4697 with SysExcSvc or SysReadSvc and a ServiceFileName containing cmd /c plus a Temp cmd_cmd_*.bat path. Legitimate activity can be separated through software ownership, signer and hash validation, server role, change records and adjacent file/process evidence.

REQUIRED TELEMETRY

SecurityEvent • 4697

- Windows Security Event 4697.
- SecurityEvent connector via AMA.
- ServiceName and ServiceFileName.

OPTIONAL ENRICHMENT

Context that improves disposition

- TrueConf server inventory and version.
- File creation under System32\inetsrv.
- PowerShell, service-start and module-load events.

UNAVAILABLE HERE

Do not infer

- Batch or DLL content from Event 4697.
- Proof that the registered command executed.
- Exploit, C2 and credential-dump success.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Sentinel · SecurityEvent · 4697

SecurityEvent documents EventID, ServiceName, ServiceFileName, service metadata, subject identity, host, record ID and resource context. Windows documents that Event 4697 is emitted when a service is installed and that ServiceFileName includes command-line parameters.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The event establishes service installation metadata at creation time. It does not establish later command execution or malicious outcome.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Service event	SecurityEvent / EventID	4697 installation event.	REQUIRED
Service identity	ServiceName	SysExcSvc or SysReadSvc.	REQUIRED
Service command	ServiceFileName	cmd /c and Temp batch pattern.	REQUIRED
Host	Computer, _ResourceId	Asset pivot.	REQUIRED
Event identity	TimeGenerated, EventRecordId	Raw record pivot.	REQUIRED
Subject	SubjectUserSid, SubjectUserName, SubjectDomainName	Installer identity.	REQUIRED
Logon context	SubjectLogonId	Neighboring authentication pivot.	OPTIONAL
Service metadata	ServiceType, ServiceStartType, ServiceAccount	Triage enrichment.	OPTIONAL

Data quality requirements

- Confirm Event 4697 collection on TrueConf and Windows servers.
- Verify ServiceName and ServiceFileName population.
- Replay a benign service install using the complete command pattern.
- Review all historical matches with platform owners.

Known failure conditions

- Audit Security System Extension is disabled.
- The connector drops Event 4697 or event-specific fields.
- The actor changes service names or avoids a batch file.
- A service is modified after creation; Event 4697 records only initial configuration.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find source-observed PhantomGraph service installation.

Select Event 4697 records only when a documented service name, cmd /c invocation, temporary directory and cmd_cmd_batch pattern occur together.

ANALYTICAL LOGIC

Direct filters and investigable output.

Six direct predicates; no join, sequence, threshold, aggregation, rarity, hash, domain, regex, external lookup or automatic attribution.

KQL · UNTESTED HUNT

```
// Head Mare / PhantomGraph Windows service persistence
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Primary platform: Microsoft Sentinel / Log Analytics
// Required connector: Windows Security Events via AMA with Event ID 4697
// Source evidence: Kaspersky observed SysExcSvc and SysReadSvc services whose
// service command invokes a %TEMP%\cmd_cmd_*.bat file through cmd /c.
// No threshold, rarity, join, sequence, hash, domain, or attribution is used.

SecurityEvent
| where EventID == 4697
| where ServiceName in~ ("SysExcSvc", "SysReadSvc")
| where ServiceFileName contains "cmd"
| where ServiceFileName contains "/"c"
| where ServiceFileName contains @"\Temp\"
| where ServiceFileName contains "cmd_cmd_"
| where ServiceFileName contains ".bat"
| project
    TimeGenerated,
    Computer,
    EventID,
    EventRecordId,
    ServiceName,
    ServiceFileName,
    ServiceType,
    ServiceStartType,
    ServiceAccount,
    SubjectUserSid,
    SubjectUserName,
    SubjectDomainName,
    SubjectLogonId,
    Activity,
    EventSourceName,
    _ResourceId
| order by TimeGenerated desc
```

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	Computer + EventRecordId + TimeGenerated	Manual triage

What a match means

The host recorded the complete campaign-specific service installation pattern and requires immediate raw-event, file and server review.

What a match does not prove

Service start, batch execution, PhantomGraph DLL loading, TrueConf exploitation, OneDrive C2, LSASS access or Head Mare attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw event.
Verify service name, complete ServiceFileName, host, installer identity and record ID.
- 02

Validate the asset.
Determine whether the host is a TrueConf server or received software from one.
- 03

Collect persistence artifacts.
Acquire the batch file, service configuration and SysExcSvc/SysReadSvc DLLs.
- 04

Rebuild execution.
Review PowerShell, cmd, service start, module load and inetsrv file events.
- 05

Scope the campaign.
Search the two service names, paths, hashes and related TrueConf installers across the estate.

Escalation gate

Escalate when the complete service pattern is unowned, appears on a TrueConf-related host, or is corroborated by unsigned installers, inetsrv DLL creation, suspicious PowerShell, service starts, LSASS access, SSH tunneling or OneDrive C2 evidence.

Primary benign overlap

Internal validation, malware analysis or an unlikely naming collision may reproduce the pattern. Tune only through verified lab scope, approved service ownership, file provenance and change records; never allowlist cmd, Temp or either service name globally.

INVESTIGATION PIVOTS

Host
TrueConf role, version, exposure and ownership.

Service
Start type, account and current ImagePath.

Batch
Path, content, creator and deletion state.

Modules
Signer, hashes and inetsrv provenance.

Identity
Subject logon and privilege context.

Network
OneDrive and SSH tunnel activity.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Controlled security replay	A lab may create the two services for validation.	Require approved operator, isolated host and test window.
Software packaging test	A developer could reuse generic service names or batch staging.	Validate publisher, package owner and signed build provenance.
Name collision	Unrelated software may use one service name.	Require the full name plus command and Temp batch combination.

Baseline plan

- Search the full available SecurityEvent retention.
- Inspect every complete pattern match.
- Measure field completeness and connector coverage.
- Do not introduce a count or rarity threshold.

Validation procedure

- Enable and confirm Audit Security System Extension in an isolated Windows lab.
- Create a disposable service reproducing the documented metadata.
- Verify all three negative cases.
- Review historical matches with TrueConf and Windows platform owners.

TEST CASES

CASE	EXPECTED RESULT
Install SysExcSvc with cmd /c and Temp\cmd_cmd_test.bat	Expected match with populated service fields.
Same service with a non-Temp binary path	No match.
Different service with the same Temp batch command	No match.
SysReadSvc with Temp batch but no cmd /c	No match; validates command boundary.

Hunting	Candidate	Production	Optimized
Initial query	Current status	Measured precision	Stable feedback

Success

The controlled service creates a complete Event 4697 match, negative cases do not, required fields are populated and historical overlap is absent or explainable.

Rejection

Event-specific fields are missing or legitimate activity frequently reproduces the full combination without a durable discriminator.

Failure

The controlled install produces no usable SecurityEvent record.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1543.003	Create or Modify System Process: Windows Service	Directly covers creation of Windows services to execute the PhantomGraph modules for persistence.

Detection coverage summary

Strong for the exact SysExcSvc/SysReadSvc plus temporary batch pattern; weak for renamed services, direct Registry/API changes, existing-service modification or missing 4697 audit coverage.

Residual risk

The actor can alter names and staging paths, modify existing services or use other persistence. Execution, module loads and C2 require separate telemetry.

ANALYST CONCLUSION

A high-value campaign hunt grounded in native service-installation telemetry.

Kaspersky directly documents the service names and command pattern, while Microsoft documents Event 4697 and every required SecurityEvent field. The combination is specific and operationally useful, but artifact mutability and tenant validation keep it at Medium-confidence Hunting status.

REFERENCES

- Kaspersky, "Head Mare APT is exploiting vulnerabilities in an unpatched TrueConf server to deliver PhantomCore and PhantomGraph to video conference participants," 11 August 2026; activity observed July 2026. [https://securelist\[.\]com/tr/head-mare-targets-trueconf-server-with-phantomcore/120988/](https://securelist[.]com/tr/head-mare-targets-trueconf-server-with-phantomcore/120988/)
- Microsoft Learn, "SecurityEvent table," updated 27 July 2026; accessed 13 August 2026. [https://learn\[.\]microsoft\[.\]com/en-us/azure/azure-monitor/reference/tables/securityevent](https://learn[.]microsoft[.]com/en-us/azure/azure-monitor/reference/tables/securityevent)
- Microsoft Learn, "4697(S): A service was installed in the system," accessed 13 August 2026. [https://learn\[.\]microsoft\[.\]com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4697](https://learn[.]microsoft[.]com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4697)
- MITRE ATT&CK, T1543.003. [https://attack\[.\]mitre\[.\]org/techniques/T1543/003/](https://attack[.]mitre[.]org/techniques/T1543/003/)

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	13 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.